SES Labs penetration test: scope and rules of engagement

Client: SyncLytics (publisher of SES Labs) · **Product:** SES Labs, version as shown on the sign-in page **Test type:** grey box (test sign-ins for every role, a till to pair, API keys and this architecture summary; no source code) **Environment:** a dedicated test copy on SyncLytics premises, holding made-up data only (see `03-test-environment.md`)

This document is part of the contract. Testing outside it is not authorised.

1. What SES Labs is

SES Labs is retail and business-management software for Ghana: a back office (accounts, stock, purchasing, payroll, reports), a till that keeps selling when the internet is down, an online shop and an API.

- **Server:** Laravel 13 (PHP 8.3 or later) with Filament 5 / Livewire for the back office, and PostgreSQL 17.
  - The Ubuntu and Docker installers put it behind nginx.
  - The Windows installer, which built the test copy, puts it behind Caddy:
    - https on port 443, with a certificate from the server's own local certificate authority (handed out at `http://<server>/ca.crt`);
    - PHP FastCGI workers on 127.0.0.1:9001–9004;
    - live updates (Laravel Reverb) on 127.0.0.1:8080, reached through Caddy at `/app`.
- **Till:** a React progressive web app served from `/pos/`. It can be installed on Windows as a Tauri desktop app.
- **Tenancy:** one server can hold several companies (tenants), and each company has branches.
- **Head office and branches:** branch servers sync with head office over signed HTTP.

Rules the software is designed to enforce, and which we want tested:

- **Companies are isolated.** Nothing in one company may be read or changed from another.
- **Deny by default.**
  - A person can do only what their role grants, and only within its scope (company, branch, warehouse or till).
  - The IT Admin role has technical rights but no business rights. It must not be able to see sales, pay or accounts.
- **Money and stock records are append-only.** Posted documents are reversed, never edited. Every change writes an audit row, and the audit log is hash-chained.
- **The till cannot be trusted with prices.** The server recalculates prices, discounts, tax and totals. Discounts, no-receipt returns and credit over the limit need a person with that right.
- **Two-step sign-in is enforced.** Back-office sign-in is a password plus an authenticator app (or passkeys), required according to the person's security level. Till staff use a PIN on a paired device, with lockout after repeated wrong PINs.

2. In scope

Area	Address / component	Main questions
Back office	`/admin` (Filament pages, Livewire `POST /livewire-*/update`, uploads, exports, imports)	Authentication, MFA bypass, session handling, role and branch escalation, cross-company access (IDOR), mass assignment, XSS, CSRF, file upload, CSV/formula injection in exports
Prints and downloads	`/print/*`, `/expense-receipt/*`, `/filament/exports/*`, `/storage/*`	Can a person fetch another person's, branch's or company's documents?
Till	`/pos/` and `/api/v1/pos/*`, `/api/v1/kds/*`, `/api/v1/wms/*`, `/api/v1/devices/*`	Device pairing, PIN brute force and lockout, offline grants (signed, time-limited), price/total/discount tampering, refund and void abuse, replay of offline sales
Public API	`/api/public/v1/*` (OpenAPI at `/api/public/v1/openapi.json`)	Key scope enforcement (the narrow key may only read products), rate limits, cross-company data, webhook registration (SSRF)
Online shop	`/shop/{slug}/*`	Cart and price tampering, order access by guessing, injection
Incoming webhooks and sync	`/api/v1/channels/*`, `/api/v1/sync/*`, `/api/license/checkin`	Signature checks, replay, forged sync batches
Public assets	`/brand/{slug}/{kind}`, `/up`	Information disclosure, SVG handling
Server configuration	The test machine as installed by our Windows installer: open ports, TLS, security headers, error pages, service accounts, file permissions	Anything an installer default gets wrong
Desktop till	The Windows till app (installer supplied)	May it navigate anywhere other than the configured server? Can a web page reach printer/drawer commands?

3. Out of scope and forbidden

- **No denial of service.** No load or stress tests and no resource-exhaustion attacks. Rate-limit checks are fine, at low volume.
- **No social engineering** of SyncLytics staff or anyone else: no phishing, phone pretexting or physical intrusion.
- **No other systems.** Do not touch any other machine on our network, our e-mail, our domains or third-party services: payment providers, GRA, SMS gateways, WooCommerce/Shopify stores, cloud storage.
  - The test copy has none of these connected.
  - If you find credentials for any of them, stop and tell us. Do not use them.
- **No real personal data.** All data is made up. Do not import real personal data.
- **Do not modify the installation files on disk.** Tampering is detected and makes the copy read-only. Report a path to doing so instead of doing it.
- **Do not attack the licence server** (SyncLytics' own systems). Only the test machine's check-in endpoint is in scope.

4. Test window and contacts

- **Window:** to be agreed, typically 5 to 10 working days, Monday to Friday, 08:00–18:00 GMT. Work outside these hours only by written agreement.
- **SyncLytics contact (technical and emergency):** name, phone and e-mail to be filled in at contract.
- **Tester contact:** the firm's lead tester, with phone.
- **Stop immediately and phone us if:**
  - you find a critical issue (remote code execution, cross-company data access, or authentication bypass);
  - the test machine becomes unavailable;
  - you find anything that looks like real personal data.

5. Method and standards

- Testing follows the **OWASP Web Security Testing Guide (WSTG)** and checks against the **OWASP ASVS 4.0 level 2**.
- The API is also tested against the **OWASP API Security Top 10**.
- Automated scanners are allowed only at low intensity. Every finding must be confirmed manually: we do not accept unverified scanner output.
- Severity is rated with **CVSS 3.1**, including the vector string.

6. What we expect back (deliverables)

1. **Report** (PDF), with:
   - a summary for management in plain language;
   - the scope actually tested and the method;
   - each finding with: title, CVSS score and vector, affected address or parameter, steps to reproduce, evidence (requests, responses and screenshots), impact in business terms, and a recommended fix.
2. **Raw findings** in CSV or JSON, so we can track them.
3. **A list of what was tested and found sound.** Good controls are evidence too.
4. **A free retest** of the fixed findings within 60 days, and an updated report or letter confirming the results.
5. **Destruction of test data.** After the final report, testers destroy their copies of the sign-ins and any data taken from the test copy, and confirm this in writing.

7. Confidentiality

- The report and everything learned about the software are confidential to SyncLytics.
- The firm may not publish findings or use them in marketing without written permission.
- A mutual non-disclosure agreement is signed before the sign-ins are handed over.